MedBridge Health, Inc.

Cybersecurity Risk Treatment Plan

1. Purpose

The purpose of this Risk Treatment Plan is to document how MedBridge Health should address the cybersecurity risks identified during its risk assessment.

Since MedBridge Health handles sensitive patient information and provides telehealth services, reducing security risks is important for protecting patient privacy, maintaining business operations, and meeting applicable compliance requirements.

This plan focuses on prioritizing security improvements, assigning responsible risk owners, and establishing proposed remediation deadlines.

2. Scope

This plan covers the 16 cybersecurity risks documented in the MedBridge Health Risk Register.

The risks involve employee security awareness, backup recovery, incident response, vendor compliance, access management, security monitoring, cloud infrastructure, application security, and network protection.

All identified risks and proposed corrective actions are based on MedBridge Health's fictional security environment.

3. Risk Treatment Approach

For this assessment, I used a 5 × 5 risk scoring matrix to evaluate likelihood and impact.

Each risk received an inherent risk score before considering the recommended security improvements.

I then estimated the target residual risk that could remain after the proposed controls are implemented and operating effectively.

The assessment uses four risk ratings:

Risk Score	Risk Rating	Priority
1–4	Low	Monitor through normal security processes.
5–9	Medium	Plan corrective actions and track progress.
10–16	High	Prioritize remediation and assign a risk owner.
17–25	Critical	Escalate to leadership for urgent risk treatment.

All 16 risks were assigned a **Mitigate** treatment recommendation because the identified weaknesses can be addressed through security improvements.

4. Risk Treatment Priorities

The assessment identified three Critical risks and thirteen High risks before the recommended improvements.

The three Critical risks are:

- **R-02 — Backup Restoration Failure:** Untested backup restoration could prevent MedBridge Health from recovering critical healthcare systems.
- **R-03 — Delayed Incident Response:** Without an implemented response process, the company could experience additional damage during a security incident.
- **R-12 — Ransomware Infection:** Ransomware could disrupt patient services and make critical systems unavailable.

These risks should receive early attention because of their potential impact on healthcare operations and patient information.

Other important priorities include addressing shared administrator accounts, improving security log monitoring, completing vendor compliance reviews, and strengthening cloud and application security.

5. Risk Treatment Action Plan

The following table summarizes the proposed corrective actions for all 16 risks.

Risk ID	Recommended Action	Risk Owner	Target Date
R-01	Implement annual security awareness training and phishing simulations.	vCISO	January 31, 2027
R-02	Conduct backup restoration testing and document recovery results.	CTO	December 15, 2026
R-03	Obtain approval for the Incident Response Policy, establish procedures, and conduct tabletop exercises.	Privacy Officer	December 15, 2026
R-04	Review vendor PHI handling and execute required Business Associate Agreements.	Privacy Officer	December 31, 2026
R-05	Establish an offboarding checklist and verify timely employee access removal.	HR Manager	January 15, 2027
R-06	Replace shared firewall administrator credentials with individual accounts.	IT Manager	December 31, 2026
R-07	Implement daily reviews of high-priority cloud security alerts.	CTO	January 15, 2027
R-08	Update the asset inventory and establish a lost-device response process.	IT Manager	February 15, 2027
R-09	Review AWS S3 permissions and implement cloud configuration monitoring.	CTO	January 15, 2027
R-10	Establish patch management procedures and prioritize critical updates.	IT Manager	January 31, 2027
R-11	Review user permissions and implement least-privilege access controls.	IT Manager	February 15, 2027
R-12	Strengthen endpoint protection, ransomware detection, and recovery testing.	CTO	December 31, 2026

Risk ID	Recommended Action	Risk Owner	Target Date
R-13	Review vendor availability commitments and document alternative workflows.	CTO	February 28, 2027
R-14	Conduct application security assessments and remediate identified weaknesses.	CTO	January 31, 2027
R-15	Improve PHI handling training and restrict unauthorized data sharing.	Privacy Officer	January 31, 2027
R-16	Review network segmentation and restrict unnecessary network access.	IT Manager	March 15, 2027

6. Expected Risk Reduction

The recommended improvements are expected to reduce the likelihood of several cybersecurity incidents.

Based on the target residual risk estimates, the overall distribution could change as follows:

Risk Rating	Inherent Risk Count	Target Residual Risk Count
Critical	3	0
High	13	3
Medium	0	12
Low	0	1
Total	**16**	**16**

7. Risk Monitoring and Tracking

The vCISO should coordinate regular risk reviews with the appropriate risk owners.

Risk treatment progress should be documented in the Risk Register using statuses such as Open, In Progress, Pending Validation, and Closed.

High and Critical risks should receive more frequent attention until the recommended corrective actions are completed.

Before closing a risk treatment action, the responsible owner should provide evidence that the control was implemented and tested.

Examples of supporting evidence include backup restoration test results, employee training records, approved vendor agreements, access review reports, and security monitoring records.

Completing a corrective action does not necessarily eliminate the risk. Any remaining risk must still be assessed and managed.

8. Management Review and Approval

The vCISO should provide management with regular updates on major cybersecurity risks, remediation progress, and issues requiring additional resources.

The CEO is responsible for reviewing major risk treatment decisions and approving high-impact security initiatives when necessary.

Risk owners are responsible for coordinating their assigned corrective actions and documenting progress.

Any decision to formally accept a significant remaining risk should be reviewed by the appropriate leadership and documented.

9. Conclusion

This Risk Treatment Plan identifies the security improvements MedBridge Health should prioritize based on its simulated cybersecurity risk assessment.

The main priorities are improving backup recovery, establishing incident response procedures, strengthening ransomware defenses, and addressing weaknesses in access management and security monitoring.

Working on this plan helped me understand how a GRC Analyst connects risk assessment findings to practical remediation activities.

I also learned why assigning risk owners, setting target dates, and tracking evidence are important for making sure security improvements are actually completed.

10. Assessment Disclaimer

This Risk Treatment Plan was created for MedBridge Health, Inc., a fictional healthcare company, as part of my hands-on GRC lab.

All risks, scores, recommendations, responsibilities, and remediation deadlines are simulated for educational purposes. The proposed security controls have not been implemented or verified.